

TLS - Transport Layer Security

Eine Betrachtung von TLS hinsichtlich Sicherheit und Robustheit

1st Hannah Herberstein
HKA
Hochschule Karlsruhe
heha1015@h-ka.de

2nd Leonie Leber
HKA
Hochschule Karlsruhe
lele1018@h-ka.de

3rd Sina Frieß
HKA
Hochschule Karlsruhe
frsi1018@h-ka.de

4th Niels Reisch
HKA
Hochschule Karlsruhe
reni1030@h-ka.de

Zusammenfassung—Transport Layer Security (TLS) bildet das kryptographische Fundament sicherer Netzwerkcommunication. Diese Arbeit analysiert den TLS-Handshake-Prozess, die Zertifikatsvalidierung sowie Vertrauensketten anhand zweier kontrastierender Client-Server-Szenarien: einer gehärteten TLS 1.3-Konfiguration mit Perfect Forward Secrecy und einem System mit veralteter Protokollversion und schwachen Cipher Suites. Am Beispiel des POODLE-Angriffs (CVE-2014-3566) wird ein gezielter Protokoll-Downgrade auf SSL 3.0 simuliert und anhand synthetischer Handshake-Logs nachvollzogen, an welcher Stelle die Sicherheitsmechanismen versagen. Ergänzend wird das Szenario eines selbstsignierten Zertifikats untersucht, das den Handshake mit einem CERTIFICATE_UNKNOWN-Alert abbricht und die Verwundbarkeit gegenüber Impersonation-Angriffen aufzeigt. Die Bewertung der Auswirkungen auf Vertraulichkeit, Integrität und Authentizität zeigt, dass Legacy-Protokolle alle drei Schutzziele gleichermaßen gefährden. Als Härungsmaßnahmen werden die ausschließliche Verwendung von TLS 1.2 und TLS 1.3, der Einsatz von Cipher Suites mit Perfect Forward Secrecy, OCSP Stapling, Certificate Transparency sowie HTTP Strict Transport Security diskutiert und im Einklang mit der BSI-Technischen Richtlinie TR-02102-2 bewertet.

Index Terms—Transport Layer Security, TLS Handshake, Downgrade-Angriff, POODLE, Cipher Suite, Perfect Forward Secrecy, Zertifikatsvalidierung, Public Key Infrastructure, Härungsmaßnahmen, IT-Sicherheit

I. EINFÜHRUNG

A. Überblick über TLS

Transport Layer Security (TLS) ist ein kryptografisches Sicherheitsprotokoll zur Absicherung der Datenübertragung in Netzwerken. Es wird eingesetzt, um die Kommunikation zwischen zwei Parteien, Client und Server, vor Abhören, Manipulation und Identitätsfälschung zu schützen. TLS ist heute der Standard zur Absicherung von TCP-basierten Anwendungen und wird unter anderem im Internetprotokoll HTTPS verwendet. TLS ist der Nachfolger von Secure Socket Layer (SSL). Obwohl häufig noch von „SSL“ gesprochen wird, kommen in modernen Systemen ausschließlich TLS-Versionen zum Einsatz. TLS arbeitet zwischen der Anwendungs- und der Transportschicht und ermöglicht eine sichere Kommunikation über unsichere Netzwerke wie das Internet.

B. Ziele von TLS

TLS verfolgt drei wesentliche Sicherheitsziele:

- **Vertraulichkeit (Confidentiality):** Schutz der übertragenen Daten vor unbefugtem Mitlesen durch Verschlüsselung.
- **Integrität (Integrity):** Sicherstellung, dass Daten während der Übertragung nicht verändert oder manipuliert wurden.
- **Authentifizierung (Authentication):** Überprüfung der Identität des Kommunikationspartners mithilfe digitaler Zertifikate.

C. Grundlegende Funktionsweise von TLS

TLS kombiniert verschiedene kryptografische Verfahren:

Symmetrische Verschlüsselung

Die eigentliche Datenübertragung erfolgt mithilfe symmetrischer Verschlüsselung. Dabei verwenden Client und Server denselben geheimen Sitzungsschlüssel (Session Key). Symmetrische Verfahren sind sehr effizient und eignen sich daher besonders für die schnelle Verschlüsselung großer Datenmengen.

Asymmetrische Verschlüsselung

Zur sicheren Aushandlung bzw. zum Schutz der Sitzungsschlüssel werden asymmetrische Verfahren eingesetzt. Hierbei existiert ein Schlüsselpaar aus Public Key und Private Key. In modernen TLS-Versionen erfolgt der Schlüsselaustausch hauptsächlich über ECDHE (Elliptic Curve Diffie-Hellman Ephemeral). Dadurch kann ein gemeinsamer geheimer Schlüssel erzeugt werden, ohne dass dieser direkt übertragen werden muss.

Integritätsschutz

TLS stellt sicher, dass Daten während der Übertragung nicht manipuliert werden. Ältere TLS-Versionen verwendeten dafür MACs (Message Authentication Codes). Moderne TLS-Versionen, insbesondere TLS 1.3, nutzen überwiegend sogenannte AEAD-Verfahren (Authenticated Encryption with Associated Data), die Verschlüsselung und Integritätsschutz kombinieren.

Authentifizierung

Die Authentifizierung erfolgt über digitale Zertifikate. Diese bestätigen die Identität des Servers und ermöglichen dem Client die Überprüfung, ob er tatsächlich mit dem gewünschten Kommunikationspartner verbunden ist.

D. Die TLS-Verbindung

Verbindungsaufbau

Eine TLS-Verbindung besteht im Wesentlichen aus vier Phasen:

- 1) TLS-Handshake
- 2) Authentifizierung und Zertifikatsprüfung
- 3) Schlüsselaustausch und Schlüsselableitung
- 4) Verschlüsselte Datenübertragung

In der Abbildung 1 im Anhang (Abschnitt A) zum TLS-1.3-Handshake ist der grundlegende Ablauf des Verbindungsaufbaus zwischen Client und Server dargestellt. Zunächst sendet der Client eine Client Hello-Nachricht an den Server. Diese enthält unter anderem die unterstützte TLS-Version, eine Liste unterstützter Cipher Suites, Zufallswerte (Client Random) sowie Parameter für den Schlüsselaustausch.

Der Server antwortet anschließend mit einer Server Hello-Nachricht. Darin teilt der Server die ausgewählte Cipher Suite mit und übermittelt sein digitales Zertifikat sowie eine digitale Signatur. Mithilfe des Zertifikats kann sich der Server gegenüber dem Client authentifizieren. Der Client überprüft daraufhin die Gültigkeit des Zertifikats sowie die Signatur der Zertifizierungsstelle.

Nach erfolgreicher Verifikation führen beide Kommunikationspartner den Schlüsselaustausch durch und erzeugen daraus einen gemeinsamen Sitzungsschlüssel (Session Key). Dieser Schlüssel wird anschließend für die symmetrische Verschlüsselung der weiteren Kommunikation verwendet. Nachdem der Handshake abgeschlossen wurde, kann die eigentliche verschlüsselte Datenübertragung beginnen.

Cipher Suites

Eine Cipher Suite beschreibt die kryptografischen Verfahren, die während der TLS-Verbindung verwendet werden. Dazu gehören unter anderem:

- Verfahren zum Schlüsselaustausch
- Verschlüsselungsalgorithmen
- Verfahren zur Integritätsprüfung

Client und Server müssen sich während des Handshakes auf eine gemeinsame Cipher Suite einigen.

Unterschiede zu älteren TLS-Versionen: In älteren TLS-Versionen wurde häufig RSA für den Schlüsselaustausch verwendet. Dabei erzeugte der Client einen geheimen Sitzungsschlüssel und verschlüsselte diesen mit dem öffentlichen Schlüssel des Servers.

TLS 1.3 unterstützt dieses Verfahren nicht mehr. Stattdessen wird überwiegend ECDHE verwendet, da dieses Verfahren sicherer ist und sogenannte Perfect Forward Secrecy ermöglicht. Dadurch bleiben vergangene Kommunikationsdaten selbst dann geschützt, wenn ein langfristiger Schlüssel kompromittiert wird.

Authentifizierung des Servers

Der Server authentifiziert sich gegenüber dem Client mithilfe eines digitalen Zertifikats. Dieses Zertifikat enthält unter anderem:

- den Domainnamen
- den öffentlichen Schlüssel des Servers
- der Gültigkeit
- Informationen über die ausstellende Zertifizierungsstelle
- die digitale Signatur der Certificate Authority (CA)

Während des TLS-Handshakes weist der Server nach, dass er im Besitz des zugehörigen Private Keys ist. Der Client überprüft anschließend die digitale Signatur des Zertifikats und kontrolliert, ob dieses von einer vertrauenswürdigen Zertifizierungsstelle ausgestellt wurde. Dadurch kann der Client sicherstellen, dass der Server authentisch ist.

Zertifikatsprüfung und Vertrauensketten

Die grundlegende Idee eines TLS-Zertifikats besteht darin, einen öffentlichen Schlüssel eindeutig mit einer Identität - meist einem Domainnamen - zu verknüpfen. Der Client vertraut dabei nicht direkt dem Serverzertifikat selbst, sondern der Zertifizierungsstelle, die dieses Zertifikat signiert hat.

Die Vertrauenskette bei TLS sieht typischerweise wie folgt aus:

```
Root CA → signiert → Intermediate CA →  
signiert → Serverzertifikat
```

Die Root Certificate Authority ist selbstsigniert und befindet sich bereits im sogenannten Trust Store des Betriebssystems oder Browsers. Dieser Trust Store enthält vertrauenswürdige Root-Zertifikate.

Aus Sicherheitsgründen signieren Root CAs Serverzertifikate normalerweise nicht direkt. Stattdessen werden sogenannte Intermediate CAs verwendet. Dies bietet mehrere Vorteile:

- höhere Sicherheit
- einfacherer Widerruf kompromittierter Zertifikate
- geringeres Risiko bei einer Kompromittierung der Root CA

Die Intermediate CA signiert anschließend das eigentliche Serverzertifikat.

Überprüfung der Zertifikatskette: Beim Verbindungsaufbau überprüft der Browser bzw. Client mehrere Punkte:

- Ist die digitale Signatur korrekt?
- Ist die Zertifikatskette vollständig?
- Ist die Root CA vertrauenswürdig?
- Ist das Zertifikat noch gültig?
- Passt der Domainname zum Zertifikat?

Kann der Client die Zertifikatskette erfolgreich bis zu einer vertrauenswürdigen Root CA zurückverfolgen, wird das Zertifikat als vertrauenswürdig akzeptiert und die Verbindung hergestellt.

Schlüsselaustausch und Session Keys

Nach erfolgreicher Authentifizierung führen Client und Server einen kryptografischen Schlüsselaustausch durch. In modernen TLS-Versionen erfolgt dies meist über ECDHE. Dabei erzeugen beide Kommunikationspartner gemeinsam einen geheimen Sitzungsschlüssel, ohne diesen direkt zu übertragen. Aus diesem Schlüsselaustausch werden anschließend die Session Keys für die symmetrische Verschlüsselung abgeleitet.

Verschlüsselte Datenübertragung

Nachdem der Handshake abgeschlossen wurde und beide Seiten gemeinsame Sitzungsschlüssel besitzen, beginnt die eigentliche Kommunikation. Die übertragenen Daten werden nun symmetrisch verschlüsselt. Zusätzlich wird ihre Integrität überprüft.

Integritätsschutz mit MACs und AEAD

Bei älteren TLS-Versionen wurde ein Message Authentication Code (MAC) verwendet. Dabei berechnen Sender und Empfänger mithilfe des gemeinsamen geheimen Schlüssels einen Prüfwert über die übertragenen Daten. Stimmen die berechneten Werte überein, wurde die Nachricht nicht manipuliert. Moderne TLS-Versionen verwenden überwiegend AEAD-Verfahren wie AES-GCM oder ChaCha20-Poly1305. Diese kombinieren Verschlüsselung und Integritätsschutz in einem einzigen Verfahren.

E. Zusammenfassung

TLS ermöglicht eine sichere Kommunikation über unsichere Netzwerke. Dazu kombiniert das Protokoll asymmetrische und symmetrische Kryptografie, digitale Zertifikate sowie kryptografische Integritätsprüfungen. Der TLS-Handshake dient dabei der sicheren Aushandlung aller benötigten Parameter und Schlüssel. Zertifikate und Vertrauensketten ermöglichen die Authentifizierung des Servers. Anschließend erfolgt die verschlüsselte und integritätsgeschützte Datenübertragung mithilfe gemeinsamer Sitzungsschlüssel.

II. KONFIGURATIONEN VON TLS

Um die im ersten Kapitel theoretischen Sicherheitsmechanismen von TLS in der Praxis zu benutzen, wird in diesem Kapitel ein empirisches Testszenario entworfen. Damit soll dargestellt werden, wie sich ein gehärtetes System gegenüber einer verwundbaren Konfiguration verhält und wie diese kommunizieren. Dadurch wird es in der Analysephase ermöglicht, die Auswirkungen auf Paket- und Log-Ebene zu identifizieren und geeignete Gegenmaßnahmen zu entwickeln.

A. Sichere Konfiguration

Für die praktische Durchführung werden zwei Client-Server-Paare definiert. Die Konfigurationsparameter wurden so gewählt, dass sie die drei Schutzziele (Vertraulichkeit, Integrität, Authentizität) beeinflussen. Zur einfacheren Darstellung sind hier die Konfigurations-Parameter genannt, die in der nachfolgenden Ausarbeitung der Client-Server-Paare erläutert werden:

- Protokollversion,
- Schlüsselaustausch-Algorithmus (Key Exchange),
- Verschlüsselungsmodus,
- Integritätsschutz,
- Zertifikatstyp und
- Schlüssellänge.

Das Client-Server-Paar 1 simuliert eine moderne TLS-Implementierung nach aktuellen Sicherheitsstandards. Es beinhaltet die sichere TLS-Konfiguration.

Als Protokollversion wird hier ausschließlich TLS 1.3 benutzt [1]. Es ist die neueste TLS-Version und verhindert veraltete, anfällige Handshake-Schritte. Dazu wird die Latenz beim Verbindungsaufbau im Gegensatz zu älteren Versionen erheblich reduziert.

Die Schlüssel-Einigung erfolgt zwingend über den ephemeren Diffie-Hellman-Algorithmus auf Basis elliptischer Kurven (ECDHE). Dadurch wird das Schutzziel der Perfect Forward Secrecy (PFS) garantiert. Somit ist ein nachträgliches Entschlüsseln des Datenverkehrs selbst bei nachträglicher Kompromittierung des Server-Schlüssels mathematisch ausgeschlossen.

Für den Verschlüsselungsmodus und Integritätsschutz wird ein AEAD-Verfahren (Authenticated Encryption with Associated Data) im Galois/Counter Mode (GCM) erzwungen [2]. Hier werden die Vertraulichkeit und der Integritätsschutz in einem Rechenschritt kombiniert, sodass kryptographische Angriffe auf die Blockstruktur des Systems verhindert werden können.

Als Zertifikatstyp nutzt dieses Client-Server-Paar ein von einer vertrauenswürdigen Certificate Authority (CA) signiertes Zertifikat. Als Algorithmus für die Bestimmung der Schlüssellänge dient entweder der Elliptic Curve Digital Signature Algorithm (ECDSA) [3] oder ein starker 4096-Bit RSA-Schlüssel gemäß den BSI-Vorgaben [4]. Beide Parameter kombiniert werden verwendet, um Identitätsfälschungen auszuschließen.

B. Veraltete Konfiguration

Das Client-Server-Paar 2 stellt ein ungepatchtes Altsystem dar und dient als Primärziel für die späteren Fehler-Simulationen. Es beinhaltet die unsichere TLS-Konfiguration.

Der Server verwendet hier das ältere Protokoll TLS 1.2. Obwohl sie mit den richtigen Chiffren sicher gemacht werden kann, erlaubt sie in dieser Konfiguration des Client-Server-Paares rückwärtskompatible, unsichere Mechanismen [5].

Als Schlüsselaustausch-Algorithmus wird ein rein statischer RSA-Schlüsselaustausch konfiguriert [6]. Hier besteht keine Forward Secrecy und gefährdet somit die Vertraulichkeit der Kommunikation auf lange Zeit, falls der Server-Schlüssel kompromittiert wird.

Die gewählte Chiffre ist eine Blockchiffre im Cipher Block Chaining (CBC) Modus. Der folgende Integritätsschutz wird sehr unsicher über einen separaten SHA-1 Message Authentication Code (MAC) berechnet. Diese Trennung der beiden Vorgänge macht das Protokoll anfällig für Angriffe auf das Block-Padding.

Der Server verwendet hier ein selbstsigniertes Zertifikat, welches keinerlei Vertrauensketten zu einer CA besitzt. Dazu wird eine mathematisch veraltete Schlüssellänge von nur 1024-Bit RSA gewählt [4]. Dies führt zu einer unzureichenden Sicherheit des Systems.

C. Konfiguration der Simulationen

Für die Umsetzung des gegebenen TLS-Szenarios wird die Open-Source-Bibliothek OpenSSL in Kombination mit dem

Netzwerkprotokoll-Analyse-Tool Wireshark verwendet [7]. Während in den Simulationen über OpenSSL die nötigen Strukturen aufgebaut werden und Handshakes direkt über das Terminal steuerbar sind, fungiert Wireshark als ein Werkzeug für die wichtige Paketaufzeichnung.

Durch das parallele Mitschneiden des Datenverkehrs wird es in der nachfolgenden Analyse ermöglicht, den genauen Fluss der Pakete visuell zu zerlegen und Schwachstellen bis zur Bit-Ebene sichtbar zu machen. Die folgenden Befehle dienen als direkte Ausführungsdokumentation für die Simulationen.

Die genaue Dokumentation der Simulationskonfiguration – einschließlich der Zertifikatsgenerierung, der Client-Server-Paar-Setups und der Fehlerfall-Szenarien – ist im Anhang (Abschnitt B) ausführlich dokumentiert. Dort finden Sie alle OpenSSL-Befehle und erwarteten Ausgaben für die sichere und unsichere TLS-Konfiguration sowie für den erfolgreichen und nicht-erfolgreichen Downgrade-Versuch.

III. EXPERIMENTELLES SETUP UND METHODIK

A. Simulationsumgebung

Um die Fehler- und Manipulationsszenarien des Transport Layer Security (TLS) praktisch zu analysieren, wurde eine kontrollierte, lokale Loopback-Umgebung (127.0.0.1) auf einem Windows-Endgerät implementiert. Als kryptographische Grundlage kam OpenSSL (Version 3.6.1) sowohl auf Client- als auch auf Server-Seite zum Einsatz [7]. Aufgezeichnet wurde der Datenverkehr parallel auf dem Loopback-Interface mittels der Netzwerk-Analysesoftware Wireshark. Außerdem wurden aktuelle Konfigurationsrichtlinien für sichere Web-Umgebungen herangezogen [8].

B. TLS-Fehlersimulation und Log-Analyse

Die Aufgabenstellung erfordert die Simulation eines Downgrade- bzw. Handshake-Fehlerfalls sowie die Analyse der Stellen, an denen Schutzmechanismen greifen oder geschwächt werden.

C. Szenario 1: Nicht-erfolgreicher Downgrade (Handshake-Fehlerfall)

Im ersten Experiment wurde untersucht, wie ein moderner Client reagiert, wenn ein Server ein veraltetes, unsicheres Protokoll erzwingt. Dies simuliert das Verhalten bei einer serverseitigen Fehlkonfiguration oder einem Manipulationsversuch im Netzpfad [9].

Vorbereitung der Zertifikate

Zunächst wurde durch die Nutzung von OpenSSL ein selbstsigniertes X.509-Zertifikat mit einem 2048-Bit RSA-Schlüsselpaar generiert. Der Parameter `-nodes` (No-DES) sorgt dafür, dass der private Schlüssel unverschlüsselt bleibt, um einen reibungslosen Serverstart ohne Passwortabfrage zu ermöglichen [7]:

```
openssl req -x509 -newkey rsa:2048 -keyout key.pem -
out cert.pem \
-days 365 -nodes
```

Verbindungsaufbau

Der simulierte Server wurde so gestartet, dass er ausschließlich das veraltete Protokoll TLS 1.0 anbietet. Anschließend versuchte der reguläre Client, eine sichere Verbindung zu diesem Port aufzubauen. Siehe Anhang C.

Analyse der Handshake-Schritte

Der Verbindungsaufbau wird durch den Client gestartet, worauf der Server antwortet und versucht, TLS 1.0 aufzuzwingen [10]. An dieser Stelle greift der clientseitige Sicherheitsmechanismus: Moderne OpenSSL-Bibliotheken blockieren standardmäßig die Kommunikation über Protokolle unterhalb von TLS 1.2 [7]. Der Handshake bricht unmittelbar ab. Das Terminal des Clients dokumentiert diesen fatalen Protokollkonflikt wie in Anhang D aufgezeigt.

In der parallelen Wireshark-Aufzeichnung zeigt sich dieser Abbruch durch ein rot markiertes Paket mit der Kennzeichnung `Alert (Level: Fatal, Description: Protocol Version (70))`. Der Fehlercode 70 (`protocol_version`) belegt, dass der Client die erzwungene Abwärtskompatibilität des Servers zum Schutz des Anwenders blockiert hat [11].

D. Szenario 2: Erfolgreicher Downgrade (Schwächung der Mechanismen)

Das zweite Experiment simuliert den Fall, in dem die clientseitigen Schutzmechanismen bewusst deaktiviert werden – beispielsweise, um die Kommunikation mit ungenügend gehärteten Altsystemen (Legacy-Systemen) im Firmennetzwerk zu erzwingen [9].

Verbindungsaufbau unter reduzierten Sicherheitsbarrieren

Nun werden der Server und der Client durch das explizite Herabsetzen des Sicherheitslevels auf die Stufe Null (`@SECLEVEL=0`) jeweils gezwungen, ihre Schutzschilde zu deaktivieren [7] (Anhang E).

Analyse der Handshake-Schritte

Durch die Modifikation signalisiert der Client bereits im *Client Hello*, dass er im Notfall auch das unsichere TLS 1.0 akzeptiert [10]. Der Server antwortet im *Server Hello* mit der Bestätigung der veralteten Version. Da der Client das nicht mehr blockiert, wechselt die Verbindung in den Zustand `CONNECTED`. Anhang F zeigt das Protokoll-Log des Terminals des Clients.

Bewertung der Schwachstelle

An dieser Stelle versagen die Sicherheitsmechanismen der Transportschicht im realen Betrieb [9]. Obwohl für den Anwender eine etablierte Verschlüsselung signalisiert wird (`CONNECTED`), ist die Vertraulichkeit und Integrität der Daten nach heutigem Standard stark gefährdet. Durch die Schwachstellen von TLS 1.0 können Angreifer im Netzpfad (Man-in-the-Middle) die Sitzung mit modernen Rechenkapazitäten passiv abhören oder manipulieren [8], [9].

E. Analytische Gegenüberstellung der Simulationsergebnisse

Zur übersichtlichen Strukturierung der Ergebnisse sind die Auswirkungen der beiden Konfigurationen in Tabelle I im Anhang (Abschnitt G) zusammenfassend gegenübergestellt.

IV. AUSWIRKUNGEN EINES FEHLERFALLS AUF SCHUTZZIELE

Die Auswirkungen der beiden untersuchten Szenarien sind in Tabelle II im Anhang (Abschnitt H) zusammengefasst.

Angriff POODLE

Der POODLE-Angriff (Padding Oracle On Downgraded Legacy Encryption, CVE-2014-3566) zeigt wie ein Angreifer eine Verbindung von TLS auf SSL 3.0 downgraded und dadurch die Verbindung kompromittiert. Die Padding-Oracle-Eigenschaft von SSL 3.0 im CBC-Modus ermöglicht die iterative Rekonstruktion von Klartextbytes durch einen Angreifer im Netzpfad (*Vertraulichkeit*). Manipulierte CBC-Blöcke werden akzeptiert, sofern das Padding zufällig korrekt ist – die MAC-then-Encrypt-Konstruktion bietet keinen ausreichenden Schutz (*Integrität*). Mit dem erzwungenen Wechsel auf SSL 3.0 entfallen die Finished-Message-Signaturen moderner TLS-Versionen; ohne TLS_FALLBACK_SCSV bleibt der Downgrade unbemerkt (*Authentizität*).

Selbstsigniertes Zertifikat

Präsentiert ein Server ein selbstsigniertes Zertifikat, bricht ein korrekt konfigurierter Client den Handshake mit einem CERTIFICATE_UNKNOWN-Alert ab – die Verbindung kommt nicht zustande. Deaktiviert ein Nutzer diese Prüfung jedoch (z. B. durch Akzeptieren einer Browser-Warnung oder mittels `--no-verify-Flag`), öffnet sich ein Angriffsfenster: Ein Angreifer im Netzpfad kann ein eigenes selbstsigniertes Zertifikat einschleusen, das der Client mangels CA-Prüfung ebenfalls akzeptiert. Damit terminiert der Angreifer *beide* TLS-Verbindungen separat – zum Client und zum echten Server – und leitet Daten transparent weiter (*Man-in-the-Middle*). Alle übertragenen Klartextdaten sind dem Angreifer zugänglich, obwohl der Nutzer eine `https://`-Verbindung im Browser sieht (*Vertraulichkeit verletzt, Authentizität verletzt*). Die TLS-Record-MAC-Prüfung schützt die Integrität *innerhalb* jeder der beiden Teilverbindungen – der Angreifer kann jedoch Inhalte modifizieren, bevor er sie in der zweiten Verbindung weitersendet, sodass der Endnutzer manipulierte Daten als integer wahrnimmt (*Integrität de facto verletzt*).

V. HÄRTUNGSMASSNAHMEN

TLS Versionsbeschränkung

Das BSI schreibt in der **Technischen Richtlinie TR-02102-2** (Stand: Januar 2026) vor, dass in neuen Systemen ausschließlich TLS 1.2 und TLS 1.3 eingesetzt werden sollen [4]. SSL 2.0, SSL 3.0 und TLS 1.0 sind vollständig zu deaktivieren; TLS 1.1 wird ebenfalls nicht mehr empfohlen. Die Konfiguration in nginx lautet entsprechend:

```
ssl_protocols TLSv1.2 TLSv1.3;
```

Durch die Abschaltung aller Legacy-Protokolle entfällt die Angriffsfläche für POODLE und BEAST [12] grundlegend, da kein Protokoll-Fallback mehr stattfinden kann [13]. Ergänzend sollte **TLS_FALLBACK_SCSV** (RFC 7507) implementiert werden: Übermittelt ein Client diesen Signaling Cipher Suite Value in einem erneuten, herabgestuften Verbindungsversuch, bricht der Server den Handshake mit einem `inappropriate_fallback`-Alert ab und verhindert so auch aktive Downgrade-Versuche bei Systemen, die Legacy-Versionen aus Kompatibilitätsgründen noch führen.

Sichere Cipher Suites

Algorithmen ohne kryptographische Langzeitsicherheit – darunter RC4, DES, 3DES, Export-Cipher und MD5-basierte MACs – sind vollständig aus der Konfiguration zu entfernen [4]. Gemäß BSI TR-02102-2 sind ausschließlich Cipher Suites mit **Perfect Forward Secrecy (PFS)** zu verwenden: Nur ephemere Schlüsselaustauschverfahren (ECDHE, DHE) stellen sicher, dass ein nachträglich kompromittierter Langzeitschlüssel keine bereits aufgezeichneten Sessions entschlüsselbar macht. Empfohlene Suites für TLS 1.2 sind:

```
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
```

Für TLS 1.3 sind die verfügbaren Cipher Suites protokollseitig bereits auf AEAD-Verfahren (AES-GCM, ChaCha20-Poly1305) beschränkt; RC4, CBC sowie der statische RSA-Schlüsseltransport sind im Standard nicht mehr vorgesehen [14].

Zertifikatsvalidierung und Vertrauensketten

Selbstsignierte Zertifikate sind in produktiven Umgebungen unzulässig. Es sind Zertifikate einer anerkannten Zertifizierungsstelle einzusetzen, deren Root-Zertifikate in den Betriebssystem- und Browser-Trust-Stores enthalten sind. Zur weiteren Absicherung der Vertrauenskette empfehlen sich folgende Mechanismen:

- **Certificate Transparency (CT):** Alle ausgestellten Zertifikate werden in öffentliche, append-only-Logs eingetragen. Clients und Monitore können überprüfen, ob ein präsentiertes Zertifikat dort verzeichnet ist, und unautorisierte Ausstellungen frühzeitig erkennen.
- **OCSP Stapling:** Der Server liefert den aktuellen Sperrstatus seines Zertifikats unmittelbar im TLS-Handshake mit, sodass der Client keinen separaten OCSP-Request senden muss. Dies verhindert, dass ein Angreifer OCSP-Abfragen blockiert und ein bereits widerrufenes Zertifikat weiterhin nutzbar bleibt.
- **CAA-DNS-Einträge:** *Certification Authority Authorization* Records schränken auf DNS-Ebene ein, welche Zertifizierungsstellen für eine Domain überhaupt Zertifikate ausstellen dürfen, und verringern so das Risiko unberechtigter Ausstellungen.

Regelmäßige Überprüfung und Patch-Management

Da Schwachstellen kontinuierlich neu entdeckt werden (vgl. MITRE CVE-Datenbank), ist eine **regelmäßige Überprüfung der TLS-Konfiguration** zwingend erforderlich. Werkzeuge wie testssl.sh oder der Qualys SSL Labs Server Test erlauben eine automatisierte Analyse aktiver Protokollversionen, Cipher Suites und Zertifikatseigenschaften. Das BSI macht die TR-02102-2 für Bundesbehörden gemäß § 8 Abs. 1 BSIG verbindlich und aktualisiert die Richtlinie fortlaufend – zuletzt im Januar 2026 [15].

ANHANG A TLS-1.3 HANDSHAKE DIAGRAMM

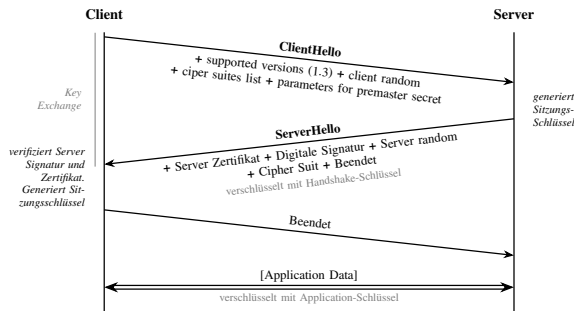


Abbildung 1. TLS 1.3 Handshake

ANHANG B DETAILLIERTE SIMULATIONS-KONFIGURATION

Generierung der Zertifikate

```
# CSP 1: ECDSA P-256 Zertifikat (sicheres Paar)
openssl ecparam -name prime256v1 -genkey -noout -out
key_secure.pem
openssl req -new -x509 -key key_secure.pem -out
cert_secure.pem \
-days 365 -subj "/CN=secure.local"

# CSP 2: RSA 1024 Bit, selbstsigniert (unsicheres
Paar)
openssl req -x509 -newkey rsa:1024 -keyout
key_insecure.pem \
-out cert_insecure.pem -days 365 -nodes \
-subj "/CN=insecure.local"
```

CSP 1 – Sicheres Paar

Terminal 1 – Server:

```
openssl s_server -accept 4433 \
-cert cert_secure.pem \
-key key_secure.pem \
-tls1_3
```

Terminal 2 – Client:

```
openssl s_client -connect localhost:4433 \
-tls1_3 \
-CAfile cert_secure.pem
```

Erwartetes Ergebnis:

```
Protocol : TLSv1.3
Cipher   : TLS_AES_256_GCM_SHA384
```

CSP 2 – Unsicheres Paar

Terminal 1 – Server:

```
openssl s_server -accept 4434 \
-cert cert_insecure.pem \
-key key_insecure.pem \
-tls1_2 \
-cipher "AES128-SHA:AES256-SHA@SECLEVEL=0"
```

Terminal 2 – Client:

```
openssl s_client -connect localhost:4434 \
-tls1_2 \
-cipher "AES128-SHA@SECLEVEL=0" \
-no-CAfile
```

Erwartetes Ergebnis:

```
Protocol : TLSv1.2
Cipher   : AES128-SHA
```

Fehler- und Downgrade-Szenarien

Nicht-erfolgreicher Downgrade: Terminal 1 – Server (sicher):

```
openssl s_server -accept 4433 \
-cert cert_secure.pem \
-key key_secure.pem \
-tls1_3
```

Terminal 2 – Client:

```
# Client versucht TLS 1.0 zu erzwingen -- Erwartet:
alert protocol version (70)
openssl s_client -connect localhost:4433 \
-tls1 \
-cipher "DEFAULT@SECLEVEL=0"
```

Erfolgreicher Downgrade: Terminal 1 – Server (unsicher):

```
openssl s_server -accept 4434 \
-cert cert_insecure.pem \
-key key_insecure.pem \
-tls1_2 \
-cipher "AES128-SHA:AES256-SHA@SECLEVEL=0"
```

Terminal 2 – Client:

```
# Client akzeptiert TLS 1.0 explizit -- Erwartet:
CONNECTED, Protocol: TLSv1
openssl s_client -connect localhost:4434 \
-tls1 \
-cipher "DEFAULT@SECLEVEL=0" \
-no-CAfile
```

ANHANG C OPENSSL-BEFEHLE SZENARIO 1

Server-Befehl (TLS 1.0 erzwingen):

```
openssl s_server -accept 4433 -cert cert.pem -key
key.pem -tls1
```

Client-Befehl (Standard-Konfiguration):

```
openssl s_client -connect localhost:4433
```

ANHANG D LOG-OUTPUT SZENARIO 1

```
CONNECTED(000001B8)
FC270000:error:0A00042E:SSL routines:ssl3_read_bytes
:
tlsv1 alert protocol version:../openssl-3.6.1/ssl/
record/
rec_layer_s3.c:918:SSL alert number 70
---
no peer certificate available
```

ANHANG E OPENSSL-BEFEHLE SZENARIO 2

Server-Befehl:

```
openssl s_server -accept 4433 -cert cert.pem -key
key.pem -tls1 \
-cipher "DEFAULT@SECLEVEL=0"
```

Client-Befehl:

```
openssl s_client -connect localhost:4433 -tls1 \
-cipher "DEFAULT@SECLEVEL=0"
```

ANHANG F LOG-OUTPUT SZENARIO 2

```
CONNECTED(000001BC)
Can't use SSL_get_servername
depth=0 C=AU, ST=Some-State
verify error:num=18:self-signed certificate
verify return:1
---
Certificate chain
 0 s:C=AU, ST=Some-State
  i:C=AU, ST=Some-State
  a:PKEY: RSA, 2048 (bit); sigalg:
  sha256WithRSAEncryption
---
New, TLSv1.0, Cipher is ECDHE-RSA-AES256-SHA
Protocol : TLSv1
Server public key is 2048 bit
Secure Renegotiation IS NOT supported
```

ANHANG G VERGLEICHSTABELLE DER SIMULATIONEN

Tabelle I
VERGLEICHSMATRIX DER SIMULIERTEN TLS-FEHLERFÄLLE

Kriterium	Szenario 1: Mismatch	Szenario 2: Downgrade
Server-Vorgabe	Erzwingung TLS 1.0	Erzwingung TLS 1.0
Client-Konfiguration	Standard (Level ≥ 1)	Deaktiviert (Level 0)
Handshake-Verlauf	Abbruch (Fatal Alert)	Erfolgreich (CONNECTED)
Log-Indikator	SSL alert number 70	Protocol: TLSv1
Sicherheitszustand	Sicher (Leitung blockiert)	Insecure (vulnerabel)

Tabelle II
AUSWIRKUNGEN AUF DIE SCHUTZZIELE (CIA)

Schutzziel	Angriff POODLE [16]	Self-Signed-Cert
Vertraulichkeit	✗ Verletzt	○ Gefährdet
Integrität	✗ Verletzt	○ Partiiell
Authentizität	✗ Verletzt	✗ Verletzt

✗ = verletzt; ○ = partiell gefährdet

ANHANG H TABELLE DER AUSWIRKUNGEN AUF SCHUTZZIELE LITERATUR

- [1] E. Rescorla, "The Transport Layer Security (TLS) Protocol Version 1.3," IETF, RFC 8446, Aug. 2018, [Online]. Verfügbar: <https://www.rfc-editor.org/info/rfc8446>.
- [2] Wikipedia, "Galois/Counter Mode," [Online]. Verfügbar: https://de.wikipedia.org/wiki/Galois/Counter_Mode.
- [3] —, "Elliptic Curve Digital Signature Algorithm (ECDSA)," [Online]. Verfügbar: <https://en.wikipedia.org/wiki/ECDSA>.
- [4] Bundesamt für Sicherheit in der Informationstechnik (BSI), "Technische Richtlinie TR-02102-2: Kryptographische Verfahren – Verwendung von Transport Layer Security (TLS)," BSI, Tech. Rep., 2026, version 2026-01. [Online]. Verfügbar: <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102.pdf>.
- [5] K. Moriarty and S. Farrell, "Deprecating TLS 1.0 and TLS 1.1," IETF, RFC 8996, Mar. 2021, [Online]. Verfügbar: <https://www.rfc-editor.org/rfc/rfc8996.pdf>.
- [6] Studyflix, "RSA-Verschlüsselung einfach erklärt," [Online]. Verfügbar: <https://studyflix.de>.
- [7] OpenSSL Project, "s_client / s_server Manual Pages," OpenSSL Software Foundation. [Online]. Verfügbar: <https://www.openssl.org/docs/>, zugriff: 02. Mai 2026.
- [8] MDN Web Docs, "Transport Layer Security (TLS)-Konfiguration," [Online]. Verfügbar: <https://developer.mozilla.org/>, zugriff: 02. Mai 2026.
- [9] SentinelOne, "Downgrade-Angriffe: Arten, Beispiele und Prävention," SentinelOne Cyber Security 101. [Online]. Verfügbar: <https://www.sentinelone.com/de/cybersecurity-101/cybersecurity/downgrade-attacks/>, zugriff: 02. Mai 2026.
- [10] D. Gitlan, "SSL/TLS Handshake: Wichtige Schritte und Bedeutung erklärt," SSL Dragon. [Online]. Verfügbar: <https://www.ssldragon.com/de/blog/tls-handshake/>, zugriff: 02. Mai 2026.
- [11] T. Becker, "TLS Protocol Defined Fatal Alert Code 70: What It Is and Why It Matters," HatchJS. [Online]. Verfügbar: <https://hatchjs.com/the-tls-protocol-defined-fatal-alert-code-is-70/>, zugriff: 21. Mai 2026.
- [12] NIST National Vulnerability Database, "CVE-2011-3389: TLS 1.0 CBC Predictable IV (BEAST)," [Online]. Verfügbar: <https://nvd.nist.gov/vuln/detail/CVE-2011-3389>, 2011.
- [13] Thomas-Krenn-Wiki, "SSL 3.0 POODLE Attack," [Online]. Verfügbar: https://www.thomas-krenn.com/de/wiki/SSL_3.0_POODLE_Attack, 2023.
- [14] Der Windows Papst, "Recommended Cipher Suites 2025," [Online]. Verfügbar: <https://www.der-windows-papst.de/2024/06/24/recommended-cipher-suites-2025/>, Jun. 2024.
- [15] kes – Zeitschrift für Informations-Sicherheit, "Technische Richtlinien des BSI zur Kryptografie," [Online]. Verfügbar: <https://www.kes-informationssicherheit.de>, 2025.
- [16] NIST National Vulnerability Database, "CVE-2014-3566: SSL 3.0 Padding Oracle Vulnerability," [Online]. Verfügbar: <https://nvd.nist.gov/vuln/detail/CVE-2014-3566>, 2014.